

1. Vulnerability Description

During the simulation, an IAM user (lab-user) was created in Amazon Web Services and assigned a custom policy (Insecure-IAM-Policy) containing overly permissive IAM-related actions. The policy included sensitive actions such as:

- iam:CreateAccessKey
- iam:AttachUserPolicy (identified during analysis)
- iam:PassRole (identified during analysis)

These permissions are considered high-risk because they enable a low-privilege user to interact with identity and access management (IAM) resources, potentially leading to credential abuse or privilege escalation.

Using the AWS CLI, the user authenticated successfully and interacted with IAM services. The following observations were recorded:

- The user was able to authenticate using AWS credentials (sts get-caller-identity).
- Attempts to enumerate IAM resources (iam:list-users, iam:get-user) were denied due to missing read permissions.
- The user successfully created access keys using iam:create-access-key, demonstrating credential generation capability.
- AWS enforced a service quota limiting the number of access keys per user (maximum of 2).

These findings confirm the presence of an IAM misconfiguration where a non-administrative user was granted permissions that could enable credential abuse and potential privilege escalation in a less restricted environment.

2. Security Impact

The misconfigured IAM policy introduced several security risks:

Credential Persistence Risk

The ability to create access keys allows an attacker to generate long-term programmatic credentials. These credentials can be used to maintain persistent access even if console credentials are changed or revoked.

Privilege Escalation Potential

Although full administrative escalation was not achieved in this simulation, permissions such as iam:AttachUserPolicy and iam:PassRole could be abused in a more permissive environment to escalate privileges to administrative level.

Reduced Visibility

The user lacked permissions to enumerate IAM users or inspect IAM configurations, demonstrating restricted visibility. This can obscure malicious activity during an attack.